

WebPwn Advanced Pentest Report

Target: https://holbertonschool.az/

Date: 2026-05-11 19:26 | Generated by WebPwn Senior Pentest Module

Executive Summary

This report presents the findings of an advanced automated security assessment against https://holbertonschool.az/. The assessment utilized senior-level heuristics to identify critical vulnerabilities across OWASP Top 10 categories. A total of 53 security findings were recorded.

Severity	Count
CRITICAL	1
HIGH	5
MEDIUM	8
LOW	2
INFO	39

Detailed Security Findings

#1 [CRITICAL] Unauthenticated Admin Access

Location: https://holbertonschool.az/admin/

CVSS Score: 9.1

Technical Details: Admin path accessible without authentication: /admin/

[!] Attacker Impact / Scenario:

High risk of system compromise. Attackers could potentially gain unauthorized access, escalate privileges, or extract sensitive data.

[+] Strategic Remediation:

Restrict admin paths to authenticated and authorized users only.

#2 [HIGH] Missing Header: Content-Security-Policy

Location: https://holbertonschool.az

CVSS Score: 7.5

Technical Details: CSP prevents XSS and data injection attacks by controlling allowed resource sources.

[!] Attacker Impact / Scenario:

Missing security headers expose users to MIME-sniffing, Clickjacking, and Cross-Site Scripting. It weakens the client-side security posture significantly.

[+] Strategic Remediation:

Configure the web server to emit standard security headers: Content-Security-Policy (CSP), X-Frame-Options, X-Content-Type-Options: nosniff, and Strict-Transport-Security (HSTS).

#3 [HIGH] Missing Header: Strict-Transport-Security

Location: <https://holbertonschool.az>

CVSS Score: 7.5

Technical Details: HSTS forces HTTPS connections and prevents SSL-stripping attacks.

[!] Attacker Impact / Scenario:

Missing security headers expose users to MIME-sniffing, Clickjacking, and Cross-Site Scripting. It weakens the client-side security posture significantly.

[+] Strategic Remediation:

Configure the web server to emit standard security headers: Content-Security-Policy (CSP), X-Frame-Options, X-Content-Type-Options: nosniff, and Strict-Transport-Security (HSTS).

#4 [HIGH] CVE: CVE-2017-16877

Location: <https://nvd.nist.gov/vuln/detail/CVE-2017-16877>

CVSS Score: 7.5 | **CVE:** CVE-2017-16877 (See NVD for details)

Technical Details: CVE-2017-16877 affects 'Next.js' — ZEIT Next.js before 2.4.1 has directory traversal under the /_next and /static request namespace, allowing attackers to obtain sensitive information.

[!] Attacker Impact / Scenario:

Attackers can exploit this known vulnerability (CVE) to execute remote code, read sensitive server files, or hijack user sessions. This puts the entire infrastructure and customer data at critical risk.

[+] Strategic Remediation:

Immediately apply the official vendor patch for the identified technology. If patching is not immediately possible, apply WAF virtual patching and restrict access to the vulnerable component.

#5 [HIGH] CVE: CVE-2018-6184

Location: <https://nvd.nist.gov/vuln/detail/CVE-2018-6184>

CVSS Score: 7.5 | **CVE:** CVE-2018-6184 (See NVD for details)

Technical Details: CVE-2018-6184 affects 'Next.js' — ZEIT Next.js 4 before 4.2.3 has Directory Traversal under the /_next request namespace.

[!] Attacker Impact / Scenario:

Attackers can exploit this known vulnerability (CVE) to execute remote code, read sensitive server files, or hijack user sessions. This puts the entire infrastructure and customer data at critical risk.

[+] Strategic Remediation:

Immediately apply the official vendor patch for the identified technology. If patching is not immediately possible, apply WAF virtual patching and restrict access to the vulnerable component.

#6 [HIGH] CVE: CVE-2024-47701

Location: <https://nvd.nist.gov/vuln/detail/CVE-2024-47701>

CVSS Score: 7.8 | **CVE:** CVE-2024-47701 (See NVD for details)

Technical Details: CVE-2024-47701 affects 'None detected' — In the Linux kernel, the following vulnerability has been resolved: ext4: avoid OOB when system.data xattr changes underneath the filesystem When looking up for an entry in an inlined directory, if

[!] Attacker Impact / Scenario:

Attackers can exploit this known vulnerability (CVE) to execute remote code, read sensitive server files, or hijack user sessions. This puts the entire infrastructure and customer data at critical risk.

[+] Strategic Remediation:

Immediately apply the official vendor patch for the identified technology. If patching is not immediately possible, apply WAF virtual patching and restrict access to the vulnerable component.

#7 [MEDIUM] Exposed Path: /admin/

Location: <https://holbertonschool.az/admin/>

CVSS Score: 5.3

Technical Details: Path accessible with HTTP 200

[!] Attacker Impact / Scenario:

Could aid attackers in reconnaissance or be chained with other vulnerabilities to compromise the application.

[+] Strategic Remediation:

Review if this path should be publicly accessible. Add authentication if needed.

#8 [MEDIUM] Exposed Path: /api-docs/

Location: <https://holbertonschool.az/api-docs/>

CVSS Score: 5.3

Technical Details: Path accessible with HTTP 200

[!] Attacker Impact / Scenario:

Could aid attackers in reconnaissance or be chained with other vulnerabilities to compromise the application.

[+] Strategic Remediation:

Review if this path should be publicly accessible. Add authentication if needed.

#9 [MEDIUM] Missing Header: X-Frame-Options

Location: <https://holbertonschool.az>

CVSS Score: 6.1

Technical Details: Missing X-Frame-Options allows clickjacking attacks (embedding site in iframes).

[!] Attacker Impact / Scenario:

Missing security headers expose users to MIME-sniffing, Clickjacking, and Cross-Site Scripting. It weakens the client-side security posture significantly.

[+] Strategic Remediation:

Configure the web server to emit standard security headers: Content-Security-Policy (CSP), X-Frame-Options, X-Content-Type-Options: nosniff, and Strict-Transport-Security (HSTS).

#10 [MEDIUM] CVE: CVE-2018-18282

Location: <https://nvd.nist.gov/vuln/detail/CVE-2018-18282>

CVSS Score: 6.1 | **CVE:** CVE-2018-18282 (See NVD for details)

Technical Details: CVE-2018-18282 affects 'Next.js' — Next.js 7.0.0 and 7.0.1 has XSS via the 404 or 500 /_error page.

[!] Attacker Impact / Scenario:

Attackers can exploit this known vulnerability (CVE) to execute remote code, read sensitive server files, or hijack user sessions. This puts the entire infrastructure and customer data at critical risk.

[+] Strategic Remediation:

Immediately apply the official vendor patch for the identified technology. If patching is not immediately possible, apply WAF virtual patching and restrict access to the vulnerable component.

#11 [MEDIUM] CVE: CVE-2020-5284

Location: <https://nvd.nist.gov/vuln/detail/CVE-2020-5284>

CVSS Score: 4.4 | **CVE:** CVE-2020-5284 (See NVD for details)

Technical Details: CVE-2020-5284 affects 'Next.js' — Next.js versions before 9.3.2 have a directory traversal vulnerability. Attackers could craft special requests to access files in the dist directory (.next). This does not affect files outside of the

[!] Attacker Impact / Scenario:

Attackers can exploit this known vulnerability (CVE) to execute remote code, read sensitive server files, or hijack user sessions. This puts the entire infrastructure and customer data at critical risk.

[+] Strategic Remediation:

Immediately apply the official vendor patch for the identified technology. If patching is not immediately possible, apply WAF virtual patching and restrict access to the vulnerable component.

#12 [MEDIUM] CVE: CVE-2020-15242

Location: <https://nvd.nist.gov/vuln/detail/CVE-2020-15242>

CVSS Score: 4.7 | **CVE:** CVE-2020-15242 (See NVD for details)

Technical Details: CVE-2020-15242 affects 'Next.js' — Next.js versions >=9.5.0 and <9.5.4 are vulnerable to an Open Redirect. Specially encoded paths could be used with the trailing slash redirect to allow an open redirect to occur to an external site. |

[!] Attacker Impact / Scenario:

Attackers can exploit this known vulnerability (CVE) to execute remote code, read sensitive server files, or hijack user sessions. This puts the entire infrastructure and customer data at critical risk.

[+] Strategic Remediation:

Immediately apply the official vendor patch for the identified technology. If patching is not immediately possible, apply WAF virtual patching and restrict access to the vulnerable component.

#13 [MEDIUM] CVE: CVE-2025-39915

Location: <https://nvd.nist.gov/vuln/detail/CVE-2025-39915>

CVSS Score: 5.5 | **CVE:** CVE-2025-39915 (See NVD for details)

Technical Details: CVE-2025-39915 affects 'None detected' — In the Linux kernel, the following vulnerability has been resolved: net: phy: transfer phy_config_inband() locking responsibility to phylink Problem description
===== Lockdep reports

[!] Attacker Impact / Scenario:

Attackers can exploit this known vulnerability (CVE) to execute remote code, read sensitive server files, or hijack user sessions. This puts the entire infrastructure and customer data at critical risk.

[+] Strategic Remediation:

Immediately apply the official vendor patch for the identified technology. If patching is not immediately possible, apply WAF virtual patching and restrict access to the vulnerable component.

#14 [MEDIUM] Business Logic / State Machine Flaw (Requires Manual Verification)

Location: <https://holbertonschool.az/>

CVSS Score: 6.5

Technical Details: Application may allow negative quantities, bypassing payment workflows, or fractional cent manipulation. Run State-Machine fuzzing on cart endpoints.

[!] Attacker Impact / Scenario:

Attackers can manipulate the application's state machine (e.g., negative quantities in cart) to steal services, purchase items for free, or cause financial loss to the business.

[+] Strategic Remediation:

Never trust client-side data. Enforce strict server-side validation for all state transitions, quantities (>0), and prices. Implement robust state-machine logic in backend controllers.

#15 [LOW] Missing Header: X-Content-Type-Options

Location: <https://holbertonschool.az/>

CVSS Score: 3.1

Technical Details: Missing header allows MIME-type sniffing, enabling content injection.

[!] Attacker Impact / Scenario:

Missing security headers expose users to MIME-sniffing, Clickjacking, and Cross-Site Scripting. It weakens the client-side security posture significantly.

[+] Strategic Remediation:

Configure the web server to emit standard security headers: Content-Security-Policy (CSP), X-Frame-Options, X-Content-Type-Options: nosniff, and Strict-Transport-Security (HSTS).

#16 [LOW] Missing Header: Referrer-Policy

Location: https://holbertonschool.az

CVSS Score: 3.1

Technical Details: Missing Referrer-Policy may leak sensitive URL information to third parties.

[!] Attacker Impact / Scenario:

Missing security headers expose users to MIME-sniffing, Clickjacking, and Cross-Site Scripting. It weakens the client-side security posture significantly.

[+] Strategic Remediation:

Configure the web server to emit standard security headers: Content-Security-Policy (CSP), X-Frame-Options, X-Content-Type-Options: nosniff, and Strict-Transport-Security (HSTS).

#17 [INFO] Port Scan

Location: holbertonschool.az:22

CVSS Score: N/A

Technical Details: Port 22 is open (SSH) — Banner: SSH-2.0-OpenSSH_9.6p1 Ubuntu-3ubuntu13.16

[!] Attacker Impact / Scenario:

Exposed network services increase the attack surface. SSH, HTTP, and non-standard ports can be exploited for brute-force, service fingerprinting, and lateral movement.

[+] Strategic Remediation:

Restrict port access via firewall rules. Only expose necessary services. Harden SSH with key-based auth and disable root login.

#18 [INFO] Port Scan

Location: holbertonschool.az:80

CVSS Score: N/A

Technical Details: Port 80 is open (HTTP) — Banner: HTTP/1.1 301 Moved Permanently

[!] Attacker Impact / Scenario:

Exposed network services increase the attack surface. SSH, HTTP, and non-standard ports can be exploited for brute-force, service fingerprinting, and lateral movement.

[+] Strategic Remediation:

Restrict port access via firewall rules. Only expose necessary services. Harden SSH with key-based auth and disable root login.

#19 [INFO] Port Scan

Location: holbertonschool.az:443

CVSS Score: N/A

Technical Details: Port 443 is open (HTTPS) — Banner: HTTP/1.1 400 Bad Request

[!] Attacker Impact / Scenario:

Exposed network services increase the attack surface. SSH, HTTP, and non-standard ports can be exploited for brute-force, service fingerprinting, and lateral movement.

[+] Strategic Remediation:

Restrict port access via firewall rules. Only expose necessary services. Harden SSH with key-based auth and disable root login.

#20 [INFO] Tech Detect

Location: https://holbertonschool.az/

CVSS Score: N/A

Technical Details: Technology detected: Nginx 1.24.0

[!] Attacker Impact / Scenario:

Could aid attackers in reconnaissance or be chained with other vulnerabilities to compromise the application.

[+] Strategic Remediation:

Follow security best practices and ensure all inputs are sanitized and dependencies updated.

#21 [INFO] Web Crawler

Location: https://holbertonschool.az/

CVSS Score: N/A

Technical Details: -

[!] Attacker Impact / Scenario:

Could aid attackers in reconnaissance or be chained with other vulnerabilities to compromise the application.

[+] Strategic Remediation:

Follow security best practices and ensure all inputs are sanitized and dependencies updated.

#22 [INFO] AWS S3

Location: http://holbertonschool.s3.amazonaws.com

CVSS Score: N/A

Technical Details: AWS S3 status: Exists (Access Denied) — http://holbertonschool.s3.amazonaws.com

[!] Attacker Impact / Scenario:

Publicly accessible cloud storage buckets (S3/GCP/Azure) can expose sensitive files, customer data, or application assets to unauthorized access or modification.

[+] Strategic Remediation:

Set bucket/blob ACL to private. Enable bucket versioning and logging. Use signed URLs for authorized access only.

#23 [INFO] Infrastructure

Location: <https://holbertonschool.az/>

CVSS Score: N/A

Technical Details: Company: 15.236.0.0/15

[!] Attacker Impact / Scenario:

Could aid attackers in reconnaissance or be chained with other vulnerabilities to compromise the application.

[+] Strategic Remediation:

Follow security best practices and ensure all inputs are sanitized and dependencies updated.

#24 [INFO] IP Prefixes

Location: <https://holbertonschool.az/>

CVSS Score: N/A

Technical Details: 2600:1f60:e080::/48, 99.86.9.0/24, 18.96.32.0/19, 2600:1fa0:80b0::/44, 65.9.60.0/24, 185.153.59.0/24, 2600:9000:2802::/48, 204.33.176.0/20, 52.84.216.0/24, 18.239.171.0/24...

[!] Attacker Impact / Scenario:

Could aid attackers in reconnaissance or be chained with other vulnerabilities to compromise the application.

[+] Strategic Remediation:

Follow security best practices and ensure all inputs are sanitized and dependencies updated.

#25 [INFO] Exposed Path: /api

Location: <https://holbertonschool.az/api>

CVSS Score: 0.0

Technical Details: Path accessible with HTTP 301

[!] Attacker Impact / Scenario:

Could aid attackers in reconnaissance or be chained with other vulnerabilities to compromise the application.

[+] Strategic Remediation:

Review if this path should be publicly accessible. Add authentication if needed.

#26 [INFO] Exposed Path: /api-docs

Location: <https://holbertonschool.az/api-docs>

CVSS Score: 0.0

Technical Details: Path accessible with HTTP 301

[!] Attacker Impact / Scenario:

Could aid attackers in reconnaissance or be chained with other vulnerabilities to compromise the application.

[+] Strategic Remediation:

Review if this path should be publicly accessible. Add authentication if needed.

#27 [INFO] Exposed Path: /admin

Location: <https://holbertonschool.az/admin>

CVSS Score: 0.0

Technical Details: Path accessible with HTTP 301

[!] Attacker Impact / Scenario:

Could aid attackers in reconnaissance or be chained with other vulnerabilities to compromise the application.

[+] Strategic Remediation:

Review if this path should be publicly accessible. Add authentication if needed.

#28 [INFO] Missing Header: Permissions-Policy

Location: <https://holbertonschool.az>

CVSS Score: 2.0

Technical Details: Missing Permissions-Policy allows access to powerful browser APIs (camera, mic, etc.).

[!] Attacker Impact / Scenario:

Missing security headers expose users to MIME-sniffing, Clickjacking, and Cross-Site Scripting. It weakens the client-side security posture significantly.

[+] Strategic Remediation:

Configure the web server to emit standard security headers: Content-Security-Policy (CSP), X-Frame-Options, X-Content-Type-Options: nosniff, and Strict-Transport-Security (HSTS).

#29 [INFO] Missing Header: Cross-Origin-Opener-Policy

Location: <https://holbertonschool.az>

CVSS Score: 2.0

Technical Details: Missing COOP allows cross-origin pages to access window references.

[!] Attacker Impact / Scenario:

Missing security headers expose users to MIME-sniffing, Clickjacking, and Cross-Site Scripting. It weakens the client-side security posture significantly.

[+] Strategic Remediation:

Configure the web server to emit standard security headers: Content-Security-Policy (CSP), X-Frame-Options, X-Content-Type-Options: nosniff, and Strict-Transport-Security (HSTS).

#30 [INFO] Missing Header: Cross-Origin-Resource-Policy

Location: <https://holbertonschool.az>

CVSS Score: 2.0

Technical Details: Missing CORP allows cross-origin pages to load this site's resources.

[!] Attacker Impact / Scenario:

Missing security headers expose users to MIME-sniffing, Clickjacking, and Cross-Site Scripting. It weakens the client-side security posture significantly.

[+] Strategic Remediation:

Configure the web server to emit standard security headers: Content-Security-Policy (CSP), X-Frame-Options, X-Content-Type-Options: nosniff, and Strict-Transport-Security (HSTS).

#31 [INFO] Information Disclosure: X-Powered-By

Location: <https://holbertonschool.az>

CVSS Score: 2.0

Technical Details: Server technology disclosure may aid attacker fingerprinting.

[!] Attacker Impact / Scenario:

Could aid attackers in reconnaissance or be chained with other vulnerabilities to compromise the application.

[+] Strategic Remediation:

Remove X-Powered-By header from all responses.

#32 [INFO] Information Disclosure: Server

Location: <https://holbertonschool.az>

CVSS Score: 2.0

Technical Details: Server version disclosure may aid attacker fingerprinting.

[!] Attacker Impact / Scenario:

Could aid attackers in reconnaissance or be chained with other vulnerabilities to compromise the application.

[+] Strategic Remediation:

Configure web server to omit or genericize the Server header.

#33 [INFO] WAF Detected

Location: <https://holbertonschool.az/>

CVSS Score: 0.0

Technical Details: Web Application Firewall identified: Nginx (generic block). 0/8 attack payloads blocked.

[!] Attacker Impact / Scenario:

Attackers can bypass the Web Application Firewall using encoded payloads (Hex, Base64, Unicode). This renders the WAF ineffective and exposes the backend to direct injection attacks.

[+] Strategic Remediation:

Update WAF rulesets to decode and normalize all incoming traffic before signature analysis. Ensure strict input validation on the backend regardless of WAF presence.

#34 [INFO] WAF Bypass Technique — Nginx (generic block)

Location: <https://holbertonschool.az/>

CVSS Score: 0.0

Technical Details: Bypass technique for Nginx (generic block): Encode payloads: URL / double-URL / HTML entity / Unicode

[!] Attacker Impact / Scenario:

Attackers can bypass the Web Application Firewall using encoded payloads (Hex, Base64, Unicode). This renders the WAF ineffective and exposes the backend to direct injection attacks.

[+] Strategic Remediation:

Update WAF rulesets to decode and normalize all incoming traffic before signature analysis. Ensure strict input validation on the backend regardless of WAF presence.

#35 [INFO] WAF Bypass Technique — Nginx (generic block)

Location: <https://holbertonschool.az/>

CVSS Score: 0.0

Technical Details: Bypass technique for Nginx (generic block): Case variation: SeLeCt, UnIoN

[!] Attacker Impact / Scenario:

Attackers can bypass the Web Application Firewall using encoded payloads (Hex, Base64, Unicode). This renders the WAF ineffective and exposes the backend to direct injection attacks.

[+] Strategic Remediation:

Update WAF rulesets to decode and normalize all incoming traffic before signature analysis. Ensure strict input validation on the backend regardless of WAF presence.

#36 [INFO] WAF Bypass Technique — Nginx (generic block)

Location: <https://holbertonschool.az/>

CVSS Score: 0.0

Technical Details: Bypass technique for Nginx (generic block): Comment insertion: UN/**/ION SE/**/LECT

[!] Attacker Impact / Scenario:

Attackers can bypass the Web Application Firewall using encoded payloads (Hex, Base64, Unicode). This renders the WAF ineffective and exposes the backend to direct injection attacks.

[+] Strategic Remediation:

Update WAF rulesets to decode and normalize all incoming traffic before signature analysis. Ensure strict input validation on the backend regardless of WAF presence.

#37 [INFO] WAF Bypass Technique — Nginx (generic block)

Location: <https://holbertonschool.az/>

CVSS Score: 0.0

Technical Details: Bypass technique for Nginx (generic block): HTTP Parameter Pollution

[!] Attacker Impact / Scenario:

Attackers can bypass the Web Application Firewall using encoded payloads (Hex, Base64, Unicode). This renders the WAF ineffective and exposes the backend to direct injection attacks.

[+] Strategic Remediation:

Update WAF rulesets to decode and normalize all incoming traffic before signature analysis. Ensure strict input validation on the backend regardless of WAF presence.

#38 [INFO] WAF Bypass Technique — Nginx (generic block)

Location: <https://holbertonschool.az/>

CVSS Score: 0.0

Technical Details: Bypass technique for Nginx (generic block): Null byte injection: %00

[!] Attacker Impact / Scenario:

Attackers can bypass the Web Application Firewall using encoded payloads (Hex, Base64, Unicode). This renders the WAF ineffective and exposes the backend to direct injection attacks.

[+] Strategic Remediation:

Update WAF rulesets to decode and normalize all incoming traffic before signature analysis. Ensure strict input validation on the backend regardless of WAF presence.

#39 [INFO] WAF Bypass Technique — Nginx (generic block)

Location: <https://holbertonschool.az/>

CVSS Score: 0.0

Technical Details: Bypass technique for Nginx (generic block): Content-Type switching: JSON/XML/multipart

[!] Attacker Impact / Scenario:

Attackers can bypass the Web Application Firewall using encoded payloads (Hex, Base64, Unicode). This renders the WAF ineffective and exposes the backend to direct injection attacks.

[+] Strategic Remediation:

Update WAF rulesets to decode and normalize all incoming traffic before signature analysis. Ensure strict input validation on the backend regardless of WAF presence.

#40 [INFO] WAF Bypass Technique — Nginx (generic block)

Location: <https://holbertonschool.az/>

CVSS Score: 0.0

Technical Details: Bypass technique for Nginx (generic block): Slow HTTP techniques

[!] Attacker Impact / Scenario:

Attackers can bypass the Web Application Firewall using encoded payloads (Hex, Base64, Unicode). This renders the WAF ineffective and exposes the backend to direct injection attacks.

[+] Strategic Remediation:

Update WAF rulesets to decode and normalize all incoming traffic before signature analysis. Ensure strict input validation on the backend regardless of WAF presence.

#41 [INFO] WAF Bypass Technique — Nginx (generic block)

Location: <https://holbertonschool.az/>

CVSS Score: 0.0

Technical Details: Bypass technique for Nginx (generic block): IPv6 address in Host header

[!] Attacker Impact / Scenario:

Attackers can bypass the Web Application Firewall using encoded payloads (Hex, Base64, Unicode). This renders the WAF ineffective and exposes the backend to direct injection attacks.

[+] Strategic Remediation:

Update WAF rulesets to decode and normalize all incoming traffic before signature analysis. Ensure strict input validation on the backend regardless of WAF presence.

#42 [INFO] WAF Bypass Payload — URL-encoded

Location: <https://holbertonschool.az/>

CVSS Score: 0.0

Technical Details: Encoded variant: %3Cscript%3Ealert%281%29%3C/script%3E

[!] Attacker Impact / Scenario:

Attackers can bypass the Web Application Firewall using encoded payloads (Hex, Base64, Unicode). This renders the WAF ineffective and exposes the backend to direct injection attacks.

[+] Strategic Remediation:

Update WAF rulesets to decode and normalize all incoming traffic before signature analysis. Ensure strict input validation on the backend regardless of WAF presence.

#43 [INFO] WAF Bypass Payload — Double URL-encoded

Location: <https://holbertonschool.az/>

CVSS Score: 0.0

Technical Details: Encoded variant: %253Cscript%253Ealert%25281%2529%253C/script%253E

[!] Attacker Impact / Scenario:

Attackers can bypass the Web Application Firewall using encoded payloads (Hex, Base64, Unicode). This renders the WAF ineffective and exposes the backend to direct injection attacks.

[+] Strategic Remediation:

Update WAF rulesets to decode and normalize all incoming traffic before signature analysis. Ensure strict input validation on the backend regardless of WAF presence.

#44 [INFO] WAF Bypass Payload — HTML-entity

Location: <https://holbertonschool.az/>

CVSS Score: 0.0

Technical Details: Encoded variant: `<script>alert(1)</script>`

[!] Attacker Impact / Scenario:

Attackers can bypass the Web Application Firewall using encoded payloads (Hex, Base64, Unicode). This renders the WAF ineffective and exposes the backend to direct injection attacks.

[+] Strategic Remediation:

Update WAF rulesets to decode and normalize all incoming traffic before signature analysis. Ensure strict input validation on the backend regardless of WAF presence.

#45 [INFO] WAF Bypass Payload — Unicode escape

Location: <https://holbertonschool.az/>

CVSS Score: 0.0

Technical Details: Encoded variant: `<script>alert(1)</script>`

[!] Attacker Impact / Scenario:

Attackers can bypass the Web Application Firewall using encoded payloads (Hex, Base64, Unicode). This renders the WAF ineffective and exposes the backend to direct injection attacks.

[+] Strategic Remediation:

Update WAF rulesets to decode and normalize all incoming traffic before signature analysis. Ensure strict input validation on the backend regardless of WAF presence.

#46 [INFO] WAF Bypass Payload — Hex (JS)

Location: <https://holbertonschool.az/>

CVSS Score: 0.0

Technical Details: Encoded variant:

`\x3c\x73\x63\x72\x69\x70\x74\x3e\x61\x6c\x65\x72\x74\x28\x31\x29\x3c\x2f\x73\x63\x72\x69\x70\x74\x3e`

[!] Attacker Impact / Scenario:

Attackers can bypass the Web Application Firewall using encoded payloads (Hex, Base64, Unicode). This renders the WAF ineffective and exposes the backend to direct injection attacks.

[+] Strategic Remediation:

Update WAF rulesets to decode and normalize all incoming traffic before signature analysis. Ensure strict input validation on the backend regardless of WAF presence.

#47 [INFO] WAF Bypass Payload — Base64

Location: <https://holbertonschool.az/>

CVSS Score: 0.0

Technical Details: Encoded variant: PHNjcmlwdD5hbGVydCgxKTWvc2NyaXB0Pg==

[!] Attacker Impact / Scenario:

Attackers can bypass the Web Application Firewall using encoded payloads (Hex, Base64, Unicode). This renders the WAF ineffective and exposes the backend to direct injection attacks.

[+] Strategic Remediation:

Update WAF rulesets to decode and normalize all incoming traffic before signature analysis. Ensure strict input validation on the backend regardless of WAF presence.

#48 [INFO] WAF Bypass Payload — Null-byte

Location: <https://holbertonschool.az/>

CVSS Score: 0.0

Technical Details: Encoded variant: `■<script>alert(1)■</script>`

[!] Attacker Impact / Scenario:

Attackers can bypass the Web Application Firewall using encoded payloads (Hex, Base64, Unicode). This renders the WAF ineffective and exposes the backend to direct injection attacks.

[+] Strategic Remediation:

Update WAF rulesets to decode and normalize all incoming traffic before signature analysis. Ensure strict input validation on the backend regardless of WAF presence.

#49 [INFO] WAF Bypass Payload — Tab-obfuscated

Location: <https://holbertonschool.az/>

CVSS Score: 0.0

Technical Details: Encoded variant: `<scr ipt>alert(1)</scr ipt>`

[!] Attacker Impact / Scenario:

Attackers can bypass the Web Application Firewall using encoded payloads (Hex, Base64, Unicode). This renders the WAF ineffective and exposes the backend to direct injection attacks.

[+] Strategic Remediation:

Update WAF rulesets to decode and normalize all incoming traffic before signature analysis. Ensure strict input validation on the backend regardless of WAF presence.

#50 [INFO] WAF Bypass Payload — Case-mixed

Location: <https://holbertonschool.az/>

CVSS Score: 0.0

Technical Details: Encoded variant: `<sCrIpT>AlErT(1)</ScRiPt>`

[!] Attacker Impact / Scenario:

Attackers can bypass the Web Application Firewall using encoded payloads (Hex, Base64, Unicode). This renders the WAF ineffective and exposes the backend to direct injection attacks.

[+] Strategic Remediation:

Update WAF rulesets to decode and normalize all incoming traffic before signature analysis. Ensure strict input validation on the backend regardless of WAF presence.

#51 [INFO] CVE: CVE-2012-5661

Location: <https://nvd.nist.gov/vuln/detail/CVE-2012-5661>

CVSS Score: 0.0 | **CVE:** CVE-2012-5661 (See NVD for details)

Technical Details: CVE-2012-5661 affects 'None detected' — Rejected reason: DO NOT USE THIS CANDIDATE NUMBER. ConsultIDs: None. Reason: This candidate is a reservation duplicate that was detected before disclosure. Notes: None

[!] Attacker Impact / Scenario:

Attackers can exploit this known vulnerability (CVE) to execute remote code, read sensitive server files, or hijack user sessions. This puts the entire infrastructure and customer data at critical risk.

[+] Strategic Remediation:

Immediately apply the official vendor patch for the identified technology. If patching is not immediately possible, apply WAF virtual patching and restrict access to the vulnerable component.

#52 [INFO] CVE: CVE-2023-53692

Location: <https://nvd.nist.gov/vuln/detail/CVE-2023-53692>

CVSS Score: 0.0 | **CVE:** CVE-2023-53692 (See NVD for details)

Technical Details: CVE-2023-53692 affects 'None detected' — In the Linux kernel, the following vulnerability has been resolved: ext4: fix use-after-free read in ext4_find_extent for bigalloc + inline Syzbot found the following issue: loop0: detected capacity

[!] Attacker Impact / Scenario:

Attackers can exploit this known vulnerability (CVE) to execute remote code, read sensitive server files, or hijack user sessions. This puts the entire infrastructure and customer data at critical risk.

[+] Strategic Remediation:

Immediately apply the official vendor patch for the identified technology. If patching is not immediately possible, apply WAF virtual patching and restrict access to the vulnerable component.

#53 [INFO] CVE: CVE-2025-40026

Location: <https://nvd.nist.gov/vuln/detail/CVE-2025-40026>

CVSS Score: 0.0 | **CVE:** CVE-2025-40026 (See NVD for details)

Technical Details: CVE-2025-40026 affects 'None detected' — In the Linux kernel, the following vulnerability has been resolved: KVM: x86: Don't (re)check L1 intercepts when completing userspace I/O When completing emulation of instruction that generated a us

[!] Attacker Impact / Scenario:

Attackers can exploit this known vulnerability (CVE) to execute remote code, read sensitive server files, or hijack user sessions. This puts the entire infrastructure and customer data at critical risk.

[+] Strategic Remediation:

Immediately apply the official vendor patch for the identified technology. If patching is not immediately possible, apply WAF virtual patching and restrict access to the vulnerable component.
